

Simulated APT Infection: TrickBot Analysis & ISO27001 Post-Incident Review



Prepared By: Ahmad Shakla

Contents

Executive Summary	3
Incident Overview	4
MITRE ATT&CK Mapping	4
Investigation writeup	5
Detection Engineering – Sigma Rules	11
ISO/IEC 27001: Post-Incident Analysis	12
Root Cause	12
Impact	12
Applicable ISO/IEC 27001:2013 Controls	12
Lessons Learned	13
Improvement Plan.....	13

Executive Summary

This report presents a simulated analysis of a TrickBot infection in a Windows Active Directory environment. The investigation was conducted using Suricata on traffic captured in a PCAP file sourced from [malware-traffic-analysis.net](https://www.malware-traffic-analysis.net/2019/09/25/index2.html). The infection demonstrated worm-like lateral movement and advanced modular behaviors. Our response combined network-based detection, IOC extraction, MITRE ATT&CK mapping, and ISO/IEC 27001 control recommendations to assess and improve the simulated organization's security posture.

Incident Overview

Item	Details
Malware	gvju6u-lse19-698411
Initial access	HTTP download via disguised `.png` files
Infected hosts	10.9.25.102 (Workstation), 10.9.25.9 (Domain Controller)
Lateral movement	From 10.9.25.102 → 10.9.25.9 via SMB & LDAP
Environment	Windows AD Domain with open SMB communication
Analysis tools	Suricata, jq, MITRE ATT&CK, Wireshark, Virustotal

MITRE ATT&CK Mapping

Tactic	Technique ID	Name
Initial Access	T1189	Drive-by Compromise
Execution	T1204.002	User Execution: Malicious File
Persistence	T1053.005	Scheduled Task
Lateral Movement	T1021.002	SMB/Windows Admin Shares
Credential Access	T1003.001	LSASS Memory
Command and Control	T1071.001	C2 Over HTTP

Investigation writeup

The analyst made a file for the case and run suricata toolkit to start the investigation as shown in the figure below

```
[us-academy-4]-[10.10.15.118]-[htb-ac-1093318@htb-vdcacpv8n0]-[~]
[*]$ mkdir suricata-logs
[us-academy-4]-[10.10.15.118]-[htb-ac-1093318@htb-vdcacpv8n0]-[~]
[*]$ suricata -r 2019-09-25-Emotet-infection-with-Trickbot-in-AD-environment.pcap -l suricata-logs/ -k none
1/7/2025 -- 13:17:36 - <Notice> - This is Suricata version 6.0.10 RELEASE running in USER mode
1/7/2025 -- 13:17:36 - <Warning> - [ERRCODE: SC_ERR_NO_RULES(42)] - No rule files match the pattern /etc/suricata/
1/7/2025 -- 13:17:36 - <Warning> - [ERRCODE: SC_ERR_NO_RULES_LOADED(43)] - 1 rule files specified, but no rules we
1/7/2025 -- 13:17:36 - <Warning> - [ERRCODE: SC_ERR_INITIALIZATION(45)] - Unix socket: UNIX socket bind(/var/run/su
s already in use
1/7/2025 -- 13:17:36 - <Warning> - [ERRCODE: SC_ERR_INITIALIZATION(45)] - Unable to create unix command socket
1/7/2025 -- 13:17:36 - <Notice> - all 5 packet processing threads, 4 management threads initialized, engine started
1/7/2025 -- 13:17:36 - <Notice> - Signal Received. Stopping engine.
1/7/2025 -- 13:17:36 - <Notice> - Pcap-file module read 1 files, 32629 packets, 32113354 bytes

[us-academy-4]-[10.10.15.118]-[htb-ac-1093318@htb-vdcacpv8n0]-[~]
[*]$ ls suricata-logs/
eve.json fast.log stats.log suricata.log
```

Upon that the analyst saved all suricata alert events into alerts.json file

```
[us-academy-4]-[10.10.15.118]-[htb-ac-1093318@htb-vdcacpv8n0]-[~/suricata-logs]
[*]$ jq 'select(.event_type=="alert")' eve.json > alerts.json
[us-academy-4]-[10.10.15.118]-[htb-ac-1093318@htb-vdcacpv8n0]-[~/suricata-logs]
[*]$ ls
alerts.json eve.json fast.log stats.log suricata.log
```

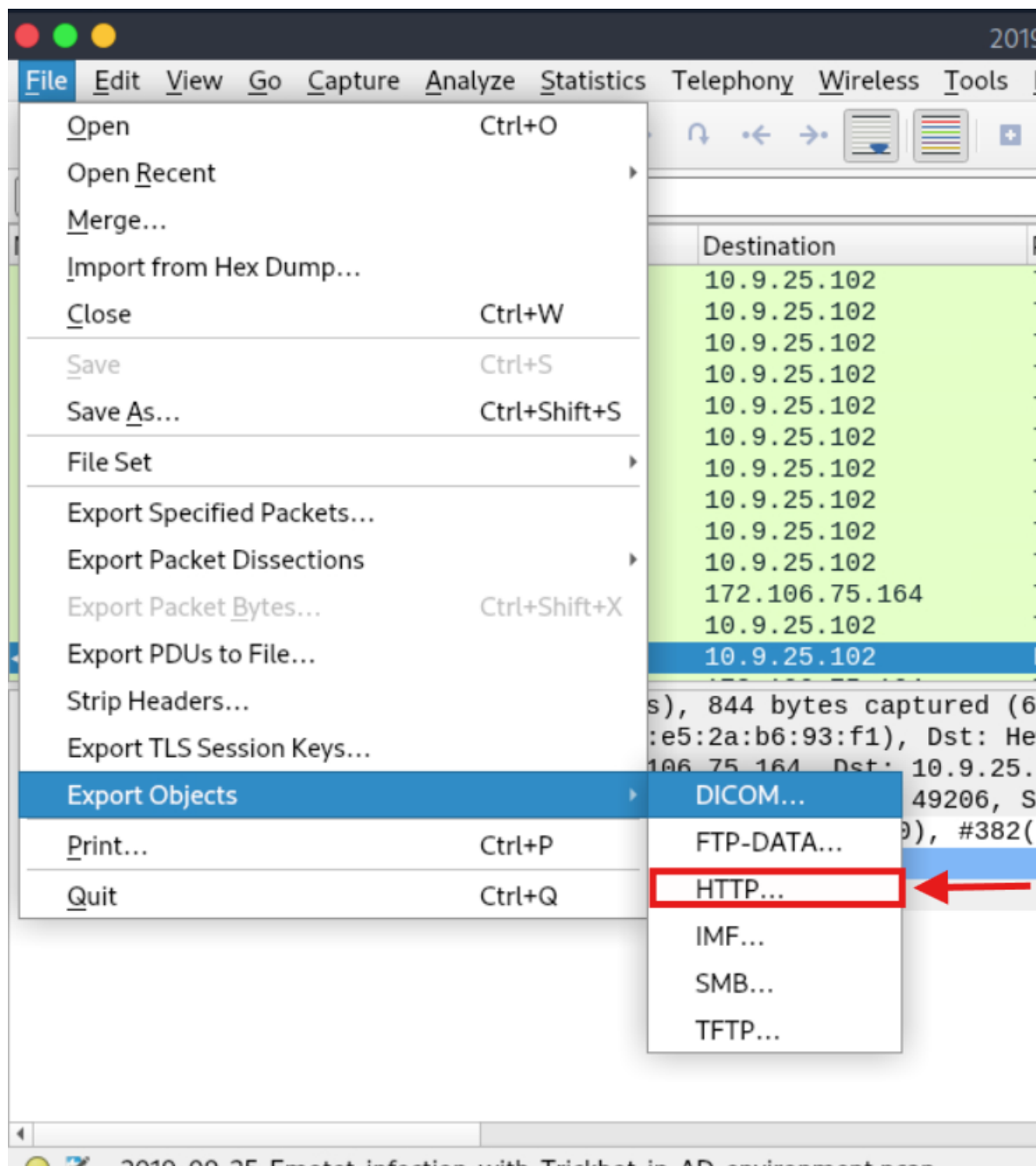
Followed by that the extraction of HTTP GET requests on the eve.json file

```
[us-academy-4]-[10.10.15.118]-[htb-ac-1093318@htb-vdcacpv8n0]-[~/suricata-logs]
[*]$ jq 'select(.event_type=="http") | {timestamp, src_ip: .src_ip, url: .http.url, host: .http.hostname}' eve.json
{
  "timestamp": "2019-09-25T16:23:59.563399-0500",
  "src_ip": "10.9.25.102",
  "url": "/ncsi.txt",
  "host": "www.msftncsi.com"
}
{
  "timestamp": "2019-09-25T16:29:02.542090-0500",
  "src_ip": "10.9.25.102",
  "url": "/wp-includes/gvju6u-lse19-698411/",
  "host": "beauty24.club"
}
{
  "timestamp": "2019-09-25T16:34:42.297126-0500",
  "src_ip": "10.9.25.102",
  "url": "/whoami.php",
  "host": "178.32.255.133"
}
{
  "timestamp": "2019-09-25T16:34:45.729392-0500",
  "src_ip": "10.9.25.102",
  "url": "/cab/mult/ringin/",
  "host": "178.32.255.133"
}
```

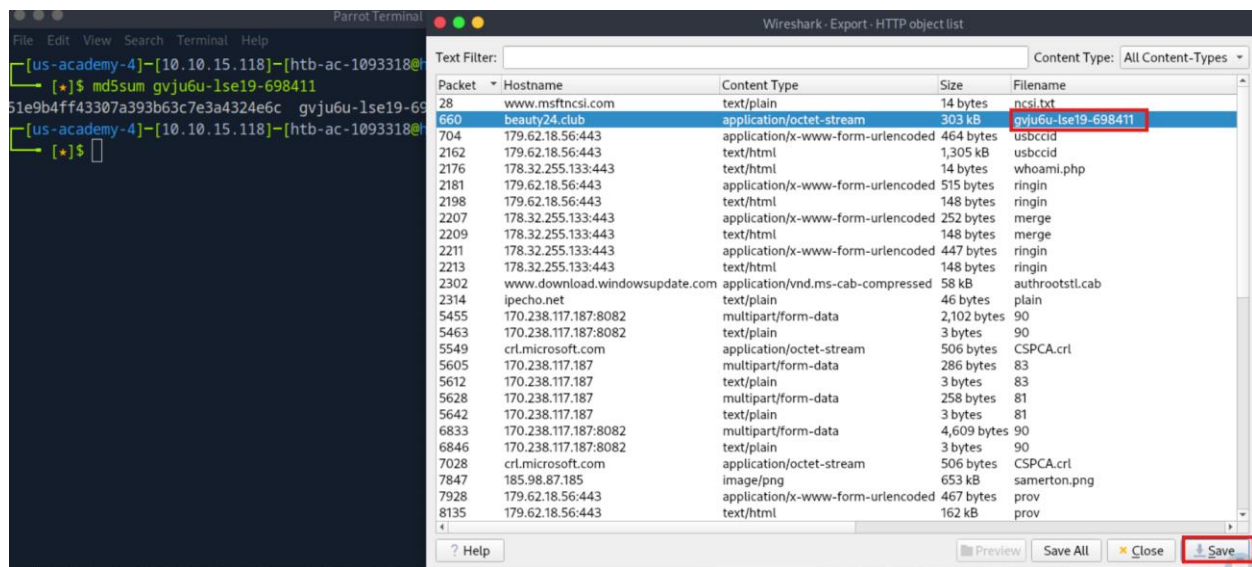
```
{
  "timestamp": "2019-09-25T17:09:49.781499-0500",
  "src_ip": "10.9.25.9",
  "url": "/samerton.png",
  "host": "185.98.87.185"
}
```

```
{
  "timestamp": "2019-09-25T16:57:13.849111-0500",
  "src_ip": "10.9.25.102",
  "url": "/wredneg2.png",
  "host": "185.98.87.185"
}
{
  "timestamp": "2019-09-25T16:57:13.728528-0500",
  "src_ip": "10.9.25.9",
  "url": "/wredneg2.png",
  "host": "185.98.87.185"
}
```

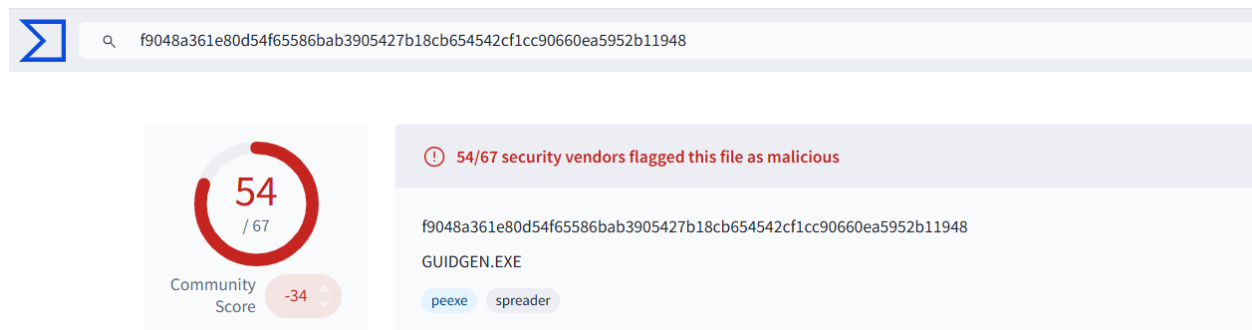
Notice the .png pictures, these ones are suspected to be the installers for an exe file, to ensure that the analyst is following a correct path, he needs to verify the integrity of the files in this GET request the analyst extracted the files using wireshark



The analyst extracted the following file and took its MD5 hash



Navigating to virustotal and placing the file's hash the analyst viewed the following results





🔍 f9048a361e80d54f65586bab3905427b18cb654542cf1cc90660ea5952b11948

MD5	51e9b4ff43307a393b63c7e3a4324e6c
SHA-1	9a4a80066c31fde5596031f5d3623cffb9b0ec6f
SHA-256	f9048a361e80d54f65586bab3905427b18cb654542cf1cc90660ea5952b11948
Vhash	035046655d157094z180078z3031z13z2006efz
Authentihash	2b262537343f3dde6c5b80d69e065c72f4e603c8b2811f3dd9d5ab0e67b68988
Imphash	6c0add4a81b3ae35e4a7093bd5f38b7c
Rich PE header hash	377d251a65373f798036ae4e463dfe94
SSDEEP	6144:fWAg+sr2J9xoWZcb0li3yFNwGgcWwZevkW:fxJEqclIM5vNh
TLSH	T1EA548D1272C1C037E5AB12754DFA8B786372FD109B3596CB27C47B4E6E31AE29A35312
File type	Win32 EXE executable windows win32 pe peexe
Magic	PE32 executable for MS Windows (GUI) Intel 80386 32-bit
TrID	Win32 Executable MS Visual C++ (generic) (48.8%) Win64 Executable (generic) (16.4%)
File size	296.00 KB (303104 bytes)

History ⓘ

Creation Time	2019-09-25 18:29:40 UTC
First Submission	2019-09-25 20:52:21 UTC
Last Submission	2025-05-13 08:50:17 UTC
Last Analysis	2022-06-09 13:36:50 UTC

Names ⓘ

gvju6u-lse19-698411
binary1.exe
gvju6u-lse19-698411.exe
knpow56_38.exe
GUIDGEN
GUIDGEN.EXE
2019-09-25-Emotet-malware-binary.exe
emotet_exe_e3_f9048a361e80d54f65586bab3905427b18cb654542cf1cc90660ea5952b11948_2019-09-25_205003.exe

The file doesn't seem to have a good reputation and is tied to the infamous Emotet malware.

After the execution of the malware the analyst noticed a bunch of SMB and LDAP traffic which suggests that the malware is using the compromised host to infect another via LDAP

```
[us-academy-4]-[10.10.15.118]-[htb-ac-1093318@htb-vdcacpv8n0]-[~]  
[*]$ jq 'select(.event_type=="smb" or .event_type=="smb_mapping")' suricata-logs/eve.json  
{  
  "timestamp": "2019-09-25T16:28:27.644439-0500",  
  "flow_id": 1347021398856199,  
  "pcap_cnt": 232,  
  "event_type": "smb",  
  "src_ip": "10.9.25.102",  
  "src_port": 49198,  
  "dest_ip": "10.9.25.9",  
  "dest_port": 445,  
  "proto": "TCP",  
  "smb": {  
    "id": 1,  
    "dialect": "2.??",  
    "command": "SMB1_COMMAND_NEGOTIATE_PROTOCOL",  
    "status": "STATUS_SUCCESS",  
    "status_code": "0x0",  
    "session_id": 0,  
    "tree_id": 0,  
    "client_dialects": [  

```

Detection Engineering – Sigma Rules

```
title: Trickbot mwormDll64 Infection via HTTP (PNG Download)
id: a1b2c3d4-5678-90ef-1234-567890abcdef
status: experimental
description: Detects Trickbot infections involving mwormDll64 module downloading payload
references:
  - https://www.malware-traffic-analysis.net/2019/09/25/index2.html
  - Trickbot gvju6u-lse19-698411 module analysis
author: Ahmad Shakla
date: 2025/7/1
tags:
  - attack.t1071.001 # MITRE: Application Layer Protocol (HTTP)
  - attack.t1105     # MITRE: Ingress Tool Transfer
  - attack.t1059.001 # MITRE: Command-Line Interface
logsource:
  category: ids
  product: wireshark
detection:
  selection:
    cs_method: "GET"
    cs_uri:
      - "/wredneg2.png"
      - "/samerton.png"
      - "/wp-includes/gvju6u-lse19-698411"
    condition: selection
falsepositives:
  - Legitimate PNG downloads (unlikely for these specific paths)
  - Internal security testing
level: high
```

ISO/IEC 27001: Post-Incident Analysis

Root Cause

- Unrestricted HTTP traffic allowed download of malware
- No egress filtering or file-type detection on gateway
- Internal lateral movement was possible via open SMB and lack of segmentation
- No anomaly-based detection on endpoints or the network

Impact

- Complete Domain Controller compromise
- Exfiltration potential
- Unauthorized access to domain assets

Applicable ISO/IEC 27001:2013 Controls

Control ID	Name	Recommended Action
A.12.4.1	Event Logging	Enable endpoint + network logs and SIEM integration
A.13.1.1	Network Controls	Network segmentation & restrict outbound HTTP
A.13.2.3	Electronic Messaging Controls	Monitor & filter suspicious file downloads
A.16.1.1	Incident Management Responsibilities	Create formal IR plan with blue team playbooks
A.18.2.2	Compliance with Security Policies and Standards	Regular auditing of endpoint & AD controls

Lessons Learned

- TrickBot can abuse legitimate protocols (HTTP, SMB) and filetypes (.png)
- Suricata proved effective for detecting this infection post-facto
- Endpoint monitoring must be improved; Sysmon + ELK or Splunk recommended
- DCs should have hardened firewall rules and deny arbitrary SMB connections

Improvement Plan

- Deploy Suricata with live log forwarding to SIEM
- Enforce egress HTTP/HTTPS whitelisting
- Apply Windows hardening baselines to critical infrastructure
- Use Sigma + YARA to enrich detection coverage
- Build an internal purple team exercise to rehearse similar infections